Sidecar Pattern

Category: Cross-cutting concerns **One-liner:** Attach a helper process alongside each service instance to handle concerns like logging, metrics, security, and networking — so the service itself contains only business logic.

Part 0 — Concepts you need first

What is a "cross-cutting concern"?

Functionality **many parts of a system** need that isn't any part's core purpose. An Order Service exists for orders — its **business logic** — but it also must log, emit **metrics** (request counts, response times), **authenticate** callers, **encrypt** traffic, retry failed calls and report **traces** (a request's path through every service). **Every service needs those**; none is about orders.

Both obvious solutions are bad:

- **Copy the code into every service** → duplication; every change touches everything
- **A shared library** every service imports → better, but see the polyglot problem below

What is a process?

A running program with its own memory. Two processes are genuinely separate — one crashing doesn't corrupt the other.

What is a container?

An application packaged with everything it needs (libraries, **configuration**), running isolated from other containers on the same machine. **Docker** is the common tool for building them.

What is a Kubernetes Pod?

The smallest deployable unit in **Kubernetes** (§ Kubernetes basics). Crucially, **a Pod can contain more than one container**, and containers in one Pod:

- Are always **scheduled onto the same machine** together
- Share a **network namespace** (one isolated set of addresses and ports) — they talk over `localhost`
- Can share **storage volumes** (mounted directories)
- Are **created and destroyed together**

This is what makes the Sidecar pattern practical. Without co-scheduling and shared networking, a "helper alongside the service" would just be another remote service.

What is a proxy?

Software that relays traffic between two parties. A **transparent** proxy does so without the application knowing — exactly how production sidecars work.

What is a service mesh?

An infrastructure layer handling all service-to-service communication: **a sidecar proxy next to every service**, plus a central **control plane** that pushes settings to all of them. **Istio** (using **Envoy**, a high-performance open-source proxy) is the best-known example. (§ Service mesh.)

The polyglot problem — why shared libraries aren't enough

Polyglot = many programming languages. You write an excellent library for retries, metrics and **mTLS** (mutual TLS: both sides present certificates proving identity, traffic encrypted). Your services are in Java, Go, Python and Node — so you maintain **four versions**. They drift: a bug fixed in Java lingers in Python for months, and a fifth language needs a fifth implementation before that team can ship.

A sidecar solves this because it's a separate process speaking network protocols — it doesn't care what language the service beside it uses.

Part 1 — The metaphor and the core idea

A **motorcycle sidecar** is attached to the motorcycle and shares the journey, yet remains a distinct unit (the course also offers Batman and Robin, or Holmes and Watson — an aide handling specific tasks autonomously within one larger entity).

The pattern applies **modularity and separation of concerns** (each piece responsible for one job): deploy components as **separate processes running alongside the main application**, each sidecar dedicated to one function. That **encapsulates the logic and complexity** of those functions in the sidecar, making each component easier to develop, manage and scale independently — and makes it possible to **use different technologies for different tasks within the same application**.

⚠️ Part 2 — One correction to the course material

The course says the sidecar and main application "run in the same process" and are "deployed together in the same container." **That is not how it works in practice:**

- The sidecar runs as a **separate process, in its own container**
- Both containers are **co-located in the same Kubernetes Pod** (or equivalent scheduling unit)
- They **share the Pod's network namespace** (hence `localhost`) and can share volumes
- They **share a lifecycle** — created, scheduled and destroyed together

Same-process or same-container would defeat the isolation that gives the pattern its value: a sidecar crash would take down the app, and you couldn't use a different language for each. The course's other framing — **same lifespan, shares resources, communicates locally** — is correct.

Part 3 — The problem: monolithic application management

Problem	What it means
Lack of isolation	In a **monolith** all components are intertwined, so **one failing component can bring down the whole application** — all eggs in one basket; no **fault isolation**
Scalability — moving the mountain	**You can't scale one component; you scale the entire application**, wasting resources
Complexity — a tangled web	As features grow, the codebase becomes hard to understand, manage or modify; maintenance slows development
Technology constraint — one size does not fit all	You're **stuck with the stack chosen at the start**; adopting new technology is a mammoth task

---

Part 4 — The solution

Pair each service with a **sidecar** that takes over some of its responsibilities; the two run side by side and communicate directly, forming a self-contained module.

- **Flexibility** — change one function by **updating the relevant sidecar, leaving the rest untouched** — no full **redeploy**.
- **Enhanced scalability** — each sidecar scales independently: surge in logins → scale the **authentication sidecar**; heavy processing → the **data-processing sidecar**.
- **Fault isolation** — a failure in one sidecar doesn't affect the others.

- **Reduced complexity** — self-contained modules are easier to understand and maintain.
- **Technology freedom** — **different technologies for different sidecars**, rather than lock-in.

Part 5 — Architecture

Co-located deployment

The application and its sidecar are deployed **together**, sharing resources and communicating efficiently — **operating as a single unit while keeping their individuality**.

Multiple sidecars

Not restricted to one: **several sidecars, each for a specific function** (logging, metrics, proxying…), modularising the application.

The network navigator — the sidecar as proxy

The most important role, and the one that makes service meshes work: the sidecar **intercepts all incoming and outgoing network traffic** of the application, acting as a **proxy**, so it can do:

- **Load balancing** (§ Load balancers)
- **Circuit breaking** *(Circuit Breaker)*
- **Security** — including mutual TLS
- **Service discovery** *(Service Discovery)*

...leaving the application **free to focus on its primary service**.



> **Why "intercepts" is the key word.** The application doesn't call the sidecar or know it exists; it makes a normal HTTP call and traffic is transparently routed through the sidecar. That's how you add mTLS, retries and **tracing without changing a line of application code** — even code you can't easily modify.

Shared lifespan

Sidecar and app are **created, deployed and destroyed together**, so the app **always has its sidecar beside it**. That guarantee matters: if the sidecar could be scheduled elsewhere or restart independently, the app would have to handle its absence — reintroducing the complexity you removed.

Part 6 — Worked example

The main application — a Spring Boot REST service

(**Spring Boot**: Java framework for building web services; a **REST** service answers plain HTTP requests on URLs such as `/api`.)

```java
@SpringBootApplication
@RestController
public class MainApplication {

    public static void main(String[] args) {
        SpringApplication.run(MainApplication.class, args);
    }

    @GetMapping("/api")
    public String getData() {
        return "Hello, Sidecar!";
    }
}
```

The sidecar — a logging helper

```java
@SpringBootApplication
@RestController
public class LoggingSidecar {

    public static void main(String[] args) {
        SpringApplication.run(LoggingSidecar.class, args);
    }

    @GetMapping("/log")
    public String logRequest() {
        System.out.println("Request received at /api endpoint");
        return "Logged!";
    }
}
```

It prints a log line whenever `/log` is hit. It's Java here, but that's incidental — in practice it usually wouldn't be.

Wiring them together

```java
@GetMapping("/api")
public String getData() {
    ResponseEntity<String> response =
        restTemplate.getForEntity("http://localhost:8081/log", String.class);
    System.out.println("Response from sidecar: " + response.getBody());
    return "Hello, Sidecar!";
}
```

`RestTemplate` is Spring's HTTP client. Each `/api` hit calls the sidecar's `/log`, which logs, and the app continues. **Note** `localhost:8081` — the shared network namespace: no service discovery needed; the sidecar is always at a known local port.

> ⚠️ **Pedagogically useful but architecturally backwards.** The app *explicitly calling* the sidecar defeats the central benefit — it now knows about the sidecar, contains code **coupling** it to the sidecar's details, and breaks if the sidecar changes. Real sidecars are **transparent**, intercepting traffic unknown to the app (as Istio/Envoy do below). Read this as "how two co-located processes communicate", not the intended usage.

The deployment factor

The example skips deployment. In production: **Docker** packages the app and sidecar; **Kubernetes orchestrates** them (starts, places, restarts, scales). Kubernetes has **built-in support for sidecar containers**, making it the natural platform.

Part 7 — Performance implications

"Does a sidecar slow my application down?" A real trade-off.

Resource cost

Each sidecar is an **additional process** — more CPU, memory and network **bandwidth**. Small individually, but **multiplied by every instance**: with hundreds or thousands of instances, **cumulative usage becomes significant**.

> Concretely: 100 MB per sidecar × 1,000 pods = 100 GB of RAM spent on infrastructure rather than application work — the most common objection to adopting a service mesh.

Latency

An **additional hop** adds **latency**. It's **usually negligible** — a **loopback** connection (traffic never leaving the machine) inside the Pod, not a real network traversal — but in **high-performance, low-latency systems it can matter**; measure rather than assume.

The verdict

The slight performance cost often **pales next to the benefits** in functionality, maintainability and operations — but weigh it for your situation.

Part 8 — Special considerations

1. **Sidecar and main application versioning.** You version **both**. What if a new sidecar is **incompatible with an older app version**, or vice versa? How do you **roll out** updates across a **fleet** (all running instances)? Answer before adopting, not after.
2. **Shared resources.** Sidecars share network and disk with the app and must **not hog them** — use **container-level resource limits and quotas** (hard caps on CPU and memory). Without limits, a misbehaving sidecar — say one **buffering** logs in memory during a log-collector **outage** — can starve the very application it supports.
3. **Security.** Sidecars often need **permissions similar to the app's**, which **increases the attack surface**. An mTLS sidecar holds **private keys** (whoever has them can impersonate the service); a log sidecar can read application output. Compromising the sidecar can be as valuable as compromising the app.
4. **Complexity.** Developers and operators now manage **multiple parts instead of one application**; debugging a request means reasoning about the app *and* the proxy in front of it. Not a one-size-fits-all solution.

Part 9 — Use cases

- **Monitoring and metrics collection** — embedding monitoring code in every app is complex; a sidecar collects metrics and keeps app code clean.
- **Logging** — a sidecar **collects logs and forwards them to a central logging system**; changing the log destination touches no application.
- **Security and authentication** — delegated to a sidecar, security is **more consistent and easier to update**: patch one sidecar image instead of auditing dozens of services.
- **Networking features** — **service discovery, connection pooling** (reusing open connections), **circuit breaking, intelligent routing**.

> The unifying test: **is this concern identical across all your services, and unrelated to what any of them does?** If yes, it's a sidecar candidate.

Part 10 — System design examples

Microservices architecture

Each microservice can have a sidecar providing **ancillary** (supporting) services — logging, monitoring, service discovery — while the service focuses on its main task.

Kubernetes and Istio — the canonical example

Istio deploys an **Envoy sidecar proxy alongside each service** to **handle all network communication**, **enforce policies**, and **collect telemetry** (metrics, logs and traces sent automatically). The application contains **zero** networking, retry, mTLS or **observability** logic; all of it lives in infrastructure, configured centrally and applied uniformly — the pattern at its purest.

Part 11 — Sidecar vs. shared library

The real decision most teams face:

	Shared library	Sidecar
Languages	One per language, maintained separately	One, language-agnostic
Upgrade	Rebuild and redeploy every service	Update the sidecar image
Runtime cost	Negligible — same process	An extra process per instance
Latency	None	A local hop
Failure isolation	A library bug crashes the app	Sidecar can fail separately
Best when	One language, few services, latency-critical	Polyglot, many services, frequent policy changes

Rule of thumb: one language and a handful of services → a library is simpler and cheaper. Several languages, many services, or a need to change cross-cutting behaviour without redeploying everything → the sidecar earns its overhead.

Part 12 — Common beginner misconceptions

- **"The sidecar and app are the same container."** Separate containers in the same Pod (Part 2).
- **"The app calls the sidecar."** In the toy example, yes; in real deployments the sidecar transparently intercepts — that transparency is the value.
- **"A sidecar is a microservice."** A **microservice** serves many clients and owns a **domain** (a business area). A sidecar serves exactly **one** application instance, owns no domain, and its lifecycle is bound to its host.
- **"Sidecars are only for service meshes."** **Log shippers** (forward logs to a central store), metrics **agents**, config reloaders and **secret-fetchers** (pull keys from a vault) are all sidecars.
- **"It's free because it's just localhost."** One process of CPU and memory **per instance** — the main reason teams hesitate.
- **"You need Kubernetes."** Pods make it easy, but the pattern predates it — anything that co-schedules two processes with shared networking works.

Part 13 — Check your understanding

1. What makes a concern a "cross-cutting" one?
2. Why doesn't a shared library solve cross-cutting concerns in a polyglot organisation?
3. What Kubernetes feature makes the pattern practical, and which two properties of it matter most?
4. Why is "intercepts" a more important word than "calls"?
5. What's the main objection to adopting a service mesh at scale?
6. When is a shared library the better choice?

(Answers: 1 — it's needed by many components but isn't the core purpose of any of them; 2 — you'd need a separate implementation per language, and they inevitably drift; 3 — the Pod, because it co-schedules containers on one machine and gives them a shared network namespace and lifecycle; 4 — interception means the application needs no knowledge or code changes, which is what lets you add mTLS and tracing to services you can't modify; 5 — cumulative resource cost, one extra process per instance across thousands of instances; 6 — a single language, few services, and latency-critical paths.)

Part 14 — Interview soundbite (30 seconds)

> "The sidecar pattern attaches a helper process beside each service instance for cross-cutting concerns — logging, metrics, auth, networking — so the service holds only business logic. It's co-located: a separate container in the same Kubernetes Pod, sharing the network namespace and lifecycle, talking over localhost. Its key role is a proxy that transparently intercepts all inbound and outbound traffic, doing load balancing, circuit breaking, mTLS and service discovery without the application knowing it exists — so you can add mTLS and distributed tracing without changing a line of code. The canonical example is Istio, with an Envoy sidecar beside every service and no networking code in the app. Over a shared library it's language-agnostic, so a polyglot estate gets consistent behaviour and you upgrade policy without redeploying every service. The costs: one extra process per instance — 100 MB across a thousand pods is 100 GB of RAM; an extra local hop; versioning the sidecar against the app; and sidecar permissions that widen your attack surface."

Part 15 — Implementation

A. Runnable demo

Full source: `demos/SidecarDemo.java`

```
cd demos && ./gradlew runCh09
```

The whole point in two class definitions. Before:

```
String handleRequest(String payload) {
    requestCount.incrementAndGet();                    // metrics
    System.out.println("[app] logging inbound request"); // logging
    if (!payload.startsWith("signed:")) return "401";    // security
    String result = businessLogic(payload);              // <- the only real work
    // ... emit latency metric
}
```

After:

```
static class CleanApp {
    String handleRequest(String payload) {
        return "order-created:" + payload;              // business logic ONLY
    }
}
```

Everything removed now lives in the sidecar, which **intercepts** rather than being called:

```
String handleInbound(String rawRequest, String clientCert) {
    if (!"valid-cert".equals(clientCert)) {
        return "403 Forbidden";                         // app never invoked
    }
    String response = app.handleRequest(rawRequest);     // plain call, no plumbing
    // ... record latency
}
```

B. What you should see

```
=== 3. mTLS enforced by the sidecar ===
  -> 403 Forbidden
  >> rejected before the application was ever invoked

=== 4. Retry + backoff, also in the sidecar ===
    [sidecar] upstream failed (connection reset), retrying
    [sidecar] upstream ok on attempt 3
  upstream was actually called 3 times; the app asked once
  >> CleanApp contains no retry code whatsoever

=== 5. Telemetry collected without any app instrumentation ===
      requests_ok        1
      requests_rejected  1
      upstream_retries   2

=== 7. The cost: resource multiplier ===
      1,000 pods x 100MB sidecar = 100,000 MB (97.7 GB) of RAM
      5,000 pods x 100MB sidecar = 500,000 MB (488.3 GB) of RAM
```

Section 4 is the pattern in one line: the **upstream** (the called service) was called three times; the application asked once — retry, backoff and failure handling happened outside your code. **Section 7 is the honest counterweight:** ~98 GB of RAM on infrastructure at a thousand pods — the number that comes up when someone asks whether the mesh is worth it.

C. Production — Istio

Injection — label the **namespace** (a named group of Kubernetes resources) and every pod gets an Envoy sidecar automatically (`kubectl` is the Kubernetes CLI):

```
kubectl label namespace production istio-injection=enabled
```

Your **Deployment** (the object describing which containers to run, and how many) is unchanged; the sidecar is added at **admission time** (when Kubernetes accepts the object and may modify it):

```
spec:
  containers:
    - name: order-service          # your app - you wrote this
      image: order-service:1.4.2
    # - name: istio-proxy          # injected automatically, you did NOT write this
```

mTLS across the whole mesh — no application code, no **certificate** (signed identity file) handling:

```yaml
apiVersion: security.istio.io/v1beta1
kind: PeerAuthentication
metadata:
  name: default
  namespace: production
spec:
  mtls:
    mode: STRICT       # every service-to-service call is encrypted and authenticated
```

Retries, timeouts and circuit breaking as configuration. A `VirtualService` sets routing rules; a `DestinationRule` sets traffic policy. **Outlier detection** temporarily *ejects* (stops routing to) instances that keep returning errors:

```yaml
apiVersion: networking.istio.io/v1beta1
kind: VirtualService
metadata:
  name: inventory
spec:
  hosts: [inventory]
  http:
    - timeout: 3s
      retries:
        attempts: 3
        perTryTimeout: 1s
        retryOn: 5xx,reset,connect-failure
      route:
        - destination: { host: inventory }
---
apiVersion: networking.istio.io/v1beta1
kind: DestinationRule
metadata:
  name: inventory
spec:
  host: inventory
  trafficPolicy:
    connectionPool:
      tcp:  { maxConnections: 100 }
      http: { http1MaxPendingRequests: 50, maxRequestsPerConnection: 10 }   # a bulkhead
    outlierDetection:                     # this IS a circuit breaker
      consecutive5xxErrors: 5
      interval: 10s
      baseEjectionTime: 30s
      maxEjectionPercent: 50
```

> **You just configured Bulkhead, Retry and Circuit Breaker in YAML, for every service, in every language, without touching application code** — the argument for a service mesh in one **manifest** (a YAML file of desired Kubernetes resources).

Non-mesh sidecars are just as common (**Fluent Bit** is a lightweight log shipper; the Cloud SQL proxy opens a secure **tunnel** — an encrypted pass-through connection — to a Google Cloud database):

```yaml
containers:
  - name: app
    image: my-app:1.0
    volumeMounts: [{ name: logs, mountPath: /var/log/app }]
  - name: log-shipper                     # sidecar: tails and ships logs
    image: fluent-bit:2.2
    volumeMounts: [{ name: logs, mountPath: /var/log/app }]
  - name: cloud-sql-proxy                 # sidecar: secure DB tunnel
    image: gcr.io/cloud-sql-connectors/cloud-sql-proxy:2.8
volumes:
  - name: logs
    emptyDir: {}                          # shared between the two containers
```

Kubernetes native sidecars (1.29+) solve the startup/shutdown ordering problem. An **initContainer** normally runs to completion before the app starts; `restartPolicy: Always` turns it into a long-running sidecar:

```
initContainers:
  - name: istio-proxy
    image: istio/proxyv2
    restartPolicy: Always        # <- makes it a true sidecar: starts first, stops last
```

D. Implementation pitfalls

1. The app starting before the sidecar is ready. The app's first outbound call fails because the proxy isn't up. Use native sidecars (`restartPolicy: Always` on an initContainer) or Istio's `holdApplicationUntilProxyStarts: true`.

2. The sidecar stopping before the app finishes. The mirror image at shutdown: **in-flight** requests fail because the proxy died first. Native sidecars fix this too.

3. No resource limits on the sidecar. An unbounded proxy can starve the app it serves. Always set them (`100m` = a tenth of a CPU core; `128Mi` = 128 mebibytes):

```
annotations:
  sidecar.istio.io/proxyCPU: "100m"
  sidecar.istio.io/proxyMemory: "128Mi"
```

4. A full mesh for three services. The resource multiplier and operational complexity are fixed costs. Below roughly a dozen services in one or two languages, a shared library is cheaper and simpler — be able to justify the mesh.

5. Forgetting the sidecar is in the network path when debugging. A 503 ("service unavailable") may come from Envoy, not your service. Learn to read the proxy's logs and response flags before blaming application code.

6. Duplicating retries in app and mesh. App client 3× and mesh 3× = 9 requests. Pick one layer — usually the mesh — and disable the other (`Retry: one layer only`).

7. Assuming mTLS means you're done with authorization. mTLS proves *who* is calling, not *what they may do* — **authorization**. You still need `AuthorizationPolicy` resources.

Related patterns

- **Service Discovery** — meshes absorb discovery into the sidecar entirely
- **Circuit Breaker**, **Retry**, **Bulkhead** — all commonly enforced in the sidecar rather than in application code
- **API Gateway** — the gateway handles north-south (external, into and out of the system) traffic; the mesh of sidecars handles east-west (internal, service-to-service)
- **Config Externalization** — a sidecar can fetch config and expose it locally to the app